

Infrastructure Security Standard

Documents Control:

Document Name	Infrastructure Security Standard
Document Owner	Head of InfoSec
Document Reviewer	Head of InfoSec
Document Approver	GLRCC
Entities Covered by this Document	Lean Group
Document Classification	Confidential
Version Number	3.0
Version Date	August 2025
Next Scheduled Review Date	August 2026
Document Description	The document defines provides a consolidated set of Infrastructure security controls that are based upon Lean security policies and standards as well as industry standards.

Version History:

Version	Type of Change	Date	Revision from previous version
1.0	Creation	October 2024	First Issue
2.0	Update	March 2025	Updates in order the Standard to meet SAMA CSF requirements

3.0	Update	August 2025	Updates on the template, as well as on the content of the document to fit the new template structure
-----	--------	-------------	--

1. Purpose

The Infrastructure Security Standard defines the controls that should be implemented and maintained to protect network components, systems, devices, etc. against unauthorized access, use, modification, or loss which might put Lean Technologies (hereinafter referred to as Lean) at risk.

2. Scope

This Standard applies to the entire Lean Technologies service ecosystem, which consists of information, system infrastructure, processes, services, information systems and computing facilities.

3. Definitions

Term	Definition
ACL	Access Control List
CIS	Center for Internet Security
CSF	Cyber Security Framework
DKIM	DomainKeys Identified Mail
DLP	Data Loss Prevention
DMARC	Domain-based Message Authentication, Reporting, and Conformance
DMZ	Demilitarized Zone
GLRCC	Governance, Legal, Risk and Compliance Committee
HTTPS	Hypertext Transfer Protocol Secure

ICMP	Internet Control Message Protocol
IDS	Intrusion Detection System
IP	Internet Protocol
IPS	Intrusion Prevention System
IT	Information Technology
KPI	Key Performance Indicator
MDM	Mobile Device Management
MPLS	Multiprotocol Label Switching
NTP	Network Time Protocol
PoLP	Principle of Least Privilege
RBAC	Role-Based Access Control
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SAMA	Saudi Arabia Monetary Authority
SFTP	Secure File Transfer Protocol
SIEM	Security Information and Event Management
SNMP	Simple Network Management Protocol
SOC	Security Operations Center
SoD	Segregation of Duties
SPF	Sender Policy Framework
SSID	Service Set Identifier
SSH	Secure Shell
SSO	Single Sign-On
SYSLOG	System Logging Protocol
TLS	Transport Layer Security
VA	Vulnerability Assessment

VLAN	Virtual Local Area Network
VPN	Virtual Private Network
WAN	Wide Area Network
WPA	Wi-Fi Protected Access

4. Infrastructure Security Standard

4.1 Network Access

1. In all circumstances, for managing the network access, Lean Technology Access Control Standard should be followed.
2. Network services along with the types of privileges shall be mapped with the job functions of the personnel involved in, to develop and maintain Access Control Matrix/Job Function Matrix.
3. Access Control Matrix/Job Function Matrix should be modified and updated based on the changes happening in personnel, job-role or network service.
4. Device management access must be allowed to authorize internal IP addresses only.
5. Generic logins should not be used to authenticate to the network and security devices administrative console.
6. Access to network infrastructure should be provided through privileged access over authentication technologies that support centralized administration and monitoring.
7. Critical network and security devices should be managed using two-factor authentication and encrypted sessions.
8. Default vendor supplied credentials should be changed.
9. In case of a complex network environment, users encountering multiple identification and authentication checks, secure single-sign on (SSO) mechanisms should be used.
10. Remote access to the Lean Technology network should be allowed only after successful authentication and must be strictly controlled through authorization mechanisms.

4.2 Network Segregation

1. Lean Technology internal network shall be segregated using VLANs.

2. Strong authentication in the form of the 802.1x standard must also be utilized.
3. Users shall be assigned to departments and groups based on their roles and responsibilities.
4. User access shall be restricted to the VLAN configured for their role.
5. All incoming and outgoing traffic should pass through and be filtered by a transport layer firewall (Internet firewall) or equivalent device as it leaves and enters Lean Technology network.
6. The Internet Firewall should only allow the minimum set of service types required for business purposes to be accessible to and from systems in the Internal Network.
7. Firewall Rules that are not timely constrained and exceed a maximum of one year with no hits must be properly eliminated unless there is a proven business request (change management request) to have it extended.
8. A DMZ (demilitarized zone) shall be created with respect to devices whose security level does not warrant them to be placed on the internal network.
9. Access lists should be put in place restricting traffic from different zones entering different networks.

4.3 Network Services and management

1. In all circumstances, for managing the network access, Lean Technology Access Management Policy shall be followed.
2. Network services (like E-mail, Internet, Remote access, Network File Server, SFTP, etc.) and various types of access privileges required to access these network services.
3. Manage the network infrastructure across network connections that are separated from the business use of that network, relying on separate VLANs for management sessions for network devices.
4. Backups of network and security devices configuration should be carried out at regular intervals and secured appropriately.

4.4 Review of Access Privileges

1. Privilege access to network devices should be reviewed on a periodic basis.
2. Administrative access to internet facing devices should be reviewed quarterly. All other administrator level access should be reviewed half-yearly.

3. Cyber Security Sector shall validate that the access rights and privileges were granted only after the approvals were obtained.
4. Cyber Security Sector shall audit and review evidence to identify if there are any unauthorized access granted.
5. Cyber Security Sector shall review to check if 'least privilege' access is granted to the users for conducting their activities.
6. Cyber Security Sector shall audit and review the evidence to identify if there were any temporary access granted earlier, with the access still alive.

4.5 Secure Network Configuration

1. Configuration changes to the network devices must be through Lean Technology's Change Management Procedures.
2. Changes to network architecture that may cause a larger impact (or cause an impact which is Lean Technology wide) should be reviewed thoroughly and approved by the Department_name.
3. All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system.
4. Network filtering technologies (firewalls, network-based IPS, routers with access controls lists, etc.) should be implemented between networks with different security levels.
5. If IPv6 is not currently being used it should be disabled.
6. A warning banner should be displayed at login to any critical system. The wording in the banner must include appropriate legal notice which can serve as a deterrent control.
7. Latest and stable version of firmware should be installed on all network devices.
8. The physical and logical access control to diagnostic and configuration ports and access to these ports are restricted to the network team.
9. Firewalls must be configured with explicit deny if no other rules are matched.
10. Access Control List (ACL) implemented on all network and security devices must be reviewed every six months, rules that are no longer required, outdated or incorrect should be removed.
11. Only authorized network and security devices should be allowed to participate in the routing announcements.
12. Unnecessary/unused ports and services on network and security devices must be disabled.

13. Secure protocols should be used, (SNMP (V3), SSH V2.0, ICMP, NTP, SYSLOG, HTTPS (TLS v2.0), etc.

4.6 Network Availability

1. Redundancy for critical networking devices should be considered and implemented.
2. Hardware availability should be ensured using suitable mechanisms like load sharing, fault detection, robust hot swap, etc.
3. Software redundancy should be ensured by using suitable mechanisms like non-stop forwarding, line card switchover, enhanced routing convergence, etc.
4. Quality of service (QoS) should be ensured which includes prioritizing and policing the available bandwidth to make sure that business critical applications get the right priority when traversing over the WAN, MPLS or VPN links.

4.7 Network Logging and Monitoring

- Network audit logs should be generated from network devices for various types of security events.
- All Network devices must be integrated with the Network Time Protocol (NTP) server.
- Network performance should be monitored as per defined KPIs.
- NIDS and NIPS should be placed strategically to detect unusual activity and cyber-attacks.
- Network monitoring should be conducted in a manner fully compatible with relevant national and international legislation and regulation.
- Ongoing monitoring should include coverage of at least the audit logs, results of scanning activities and incidents on the devices.

4.8 Network Security Compliance Review

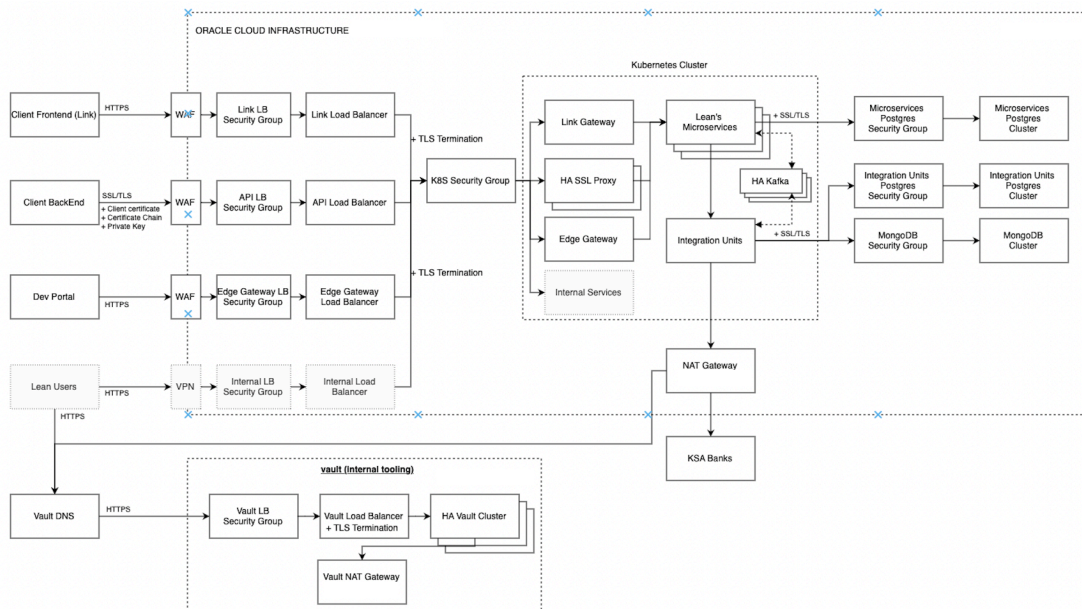
1. For all networks, security compliance review should take place against a comprehensive checklist (as per recognized industry standards) constructed by the Department_name.
2. The compliance review should occur prior to live operation of any network, prior to a major new release (related to significant business or network related change), and otherwise periodically.

3. Automated scanning tools should be used to review technical configuration settings of the network devices. Where required, a manual hardening check should be performed to compensate for limitation of the scanning tool.
4. Penetration testing of all external facing and critical network devices should be conducted. Frequency, methodology and procedures of penetration testing should be in accordance with Lean Technology Penetration Testing Methodology.

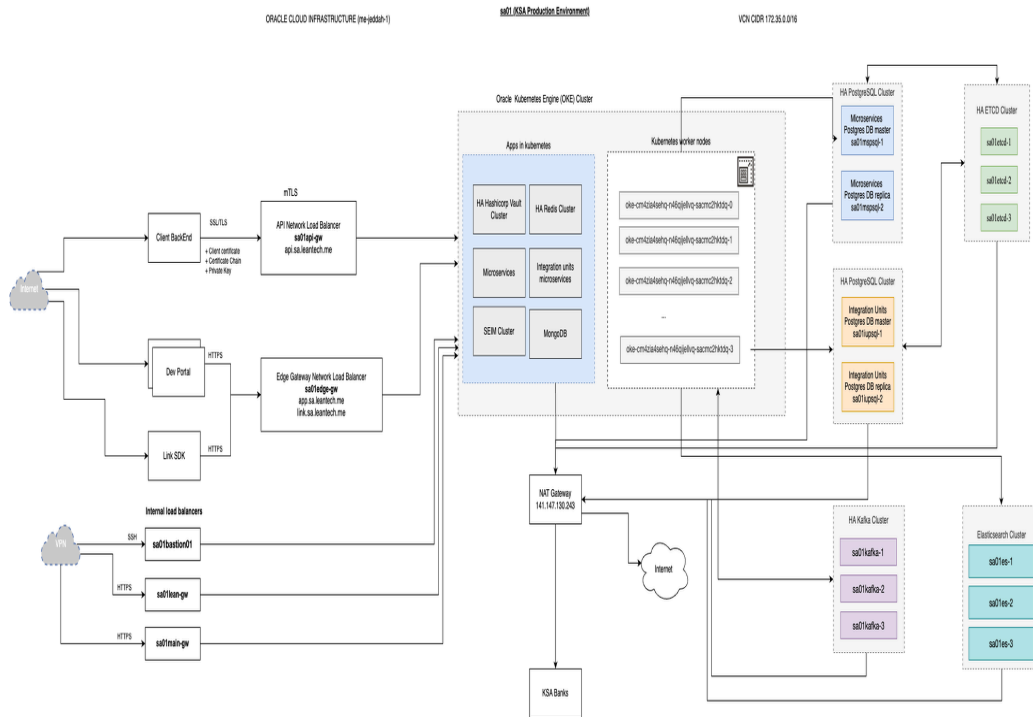
4.9 Network Diagram and Documentation

1. Lean Technology shall document and maintain
 - A. Network diagrams and reference architectures.
 - B. Network device hardening documents.
 - C. Standard operating procedures for network security operations including administration, testing, deployment, patching, troubleshooting, monitoring, etc.
 - D. Any other security related documentation.

Low Level Network diagram



Lean Infrastructure Architecture



2. Lean Technology can maintain network diagrams with varying levels of details. Example: A high-level diagram can be maintained for providing assurance to third parties. A low-level diagram can be provided to the auditor.
3. Network diagrams maintained by Lean Technology shall be updated as and when there are changes made to the network architecture.
4. Network configuration dumps/files shall be made available only to authorized individuals strictly on a need-to-know basis. Procedures must be documented to ensure secure access.
5. Roles and responsibilities of senior management, network operations manager, network security manager, administrators and network users must be defined.
6. Documentations of the outcome of testing, continuity procedures, etc. should be maintained.

4.10 Additional Security requirements

a) Physical and Environmental Security

Physical security of network equipment must comply with Lean Technology's Physical and Environmental Security Policy.



b) Access Control

Access to the network must comply with Lean Technology's Identity and Access Management Policy.

Privileged access to the network must comply with Lean Technology's Privileged Access Policy.

Third party and external access to the Lean Technology network must be based on a formal contract that satisfies all Lean Technology security conditions and defines legal responsibility with Lean Technology data they interact with and is in line with Lean Technology's Data Classification Policy to ensure the security of information in the networks and the protection of connected services from unauthorized access.

All connections to external networks and systems must be documented and approved before data exchange is permitted.

External connections must be in line with Lean Technology's Identity and Access Management Policy.

c) Wireless Networks

Users must connect to wireless networks via authorized and managed access points.

Wireless networks must utilize the latest approved level of encryption as defined in Lean Technology's Cryptography Policy.

Lean Technology network management must ensure SSIDs are centrally managed and encrypted using the latest encryption standards in line with Lean Technology's Cryptography Policy.

Unauthorized devices must be prevented from connecting to the wireless network.

Staff must not attempt to connect personally owned wireless devices to the Corporate network.

Corporate and Guest Wi-Fi networks must be segregated.

Guest Wi-Fi must enforce an acceptable use policy and block any inappropriate traffic, which must be possible for all devices connecting to it.

Guest credentials must be unique to individual users.



d) Secure Disposal or Reuse of Equipment

Lean Technology must ensure that where equipment is being disposed of or re-used, all data is sanitized in compliance with Lean Technology's Asset Management policy. More details are documented in physical security standards documents.

e) System Change Control

Lean Technology must ensure that appropriate change management processes are in place to review changes to the network, which would include acceptance testing, backout/rollback plan and authorization.

Lean Technology must ensure that Security team are involved in network changes which may impact the security of the network and assigned as change approvers in line with Lean Technology's Change Management Policy.

All changes must be logged and stored for audit purposes in line with Lean Technology's Retention and Disposal Framework Implementation Process Policy.

Testing facilities must be used for all new network systems. Development and operational facilities should be separated.

f) Reporting Data Security Breaches and Weaknesses

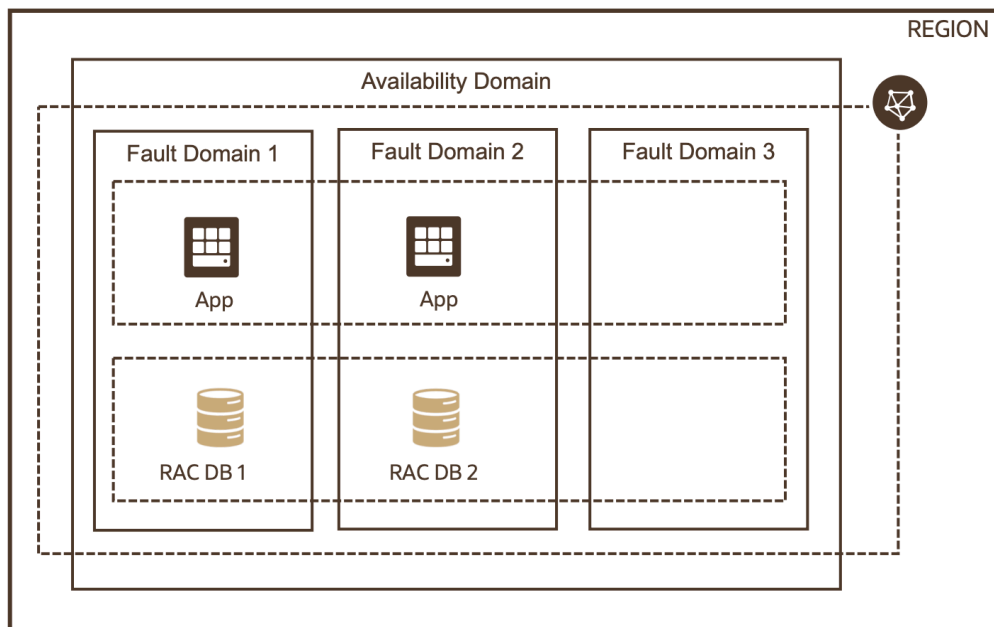
Data Security breaches and weaknesses must be reported in accordance with the requirements of Lean Technology's Information Security Incident Management Policy.

g) Disaster Recovery Plans

Lean Technology must have a disaster recovery plan for the network in accordance with the Lean Technology's Disaster Recovery plan.

Lean Technology must ensure this policy is reviewed regularly, at least annually.

Lean avoids single points of failure by distributing the workload across multiple fault domains



DR Capabilities of Oracle Cloud

Regions

Each Oracle Cloud Infrastructure region is in a geographical area that's independent and separated by vast distances—across countries or even continents, from all the other regions. You can deploy applications in different regions to mitigate the risk of region-wide events, such as large weather systems and earthquakes.

Availability domains

An availability domain is one or more data centers located within a region. Availability domains are isolated from each other, fault tolerant, and unlikely to fail simultaneously. Because availability domains don't share physical infrastructure, such as power or cooling, or the internal availability domain network, a failure that impacts one availability domain is unlikely to impact others. The availability domains within a region are interconnected by a low-latency, encrypted network.

Fault domains (1,2,3)



A fault domain is a grouping of hardware and infrastructure within an availability domain. Each availability domain contains three fault domains. Fault domains enable you to distribute your resources so that they don't depend on the same physical hardware within a single availability domain. As a result, hardware failures or maintenance events that affect one fault domain do not affect the resources in other fault domains.

a. Data in transit protection

Data in transit must be adequately protected via the latest encryption standards to protect the confidentiality and integrity of the data as defined in Lean Technology's Cryptography policy.

All connections from outside the network must be via an encrypted VPN (Virtual Private Network).

we use a double layer encryption (payload encryption + TLS 1.2 encryption) to encrypt the traffic between the client application (where user credentials are supplied) and Lean backend server

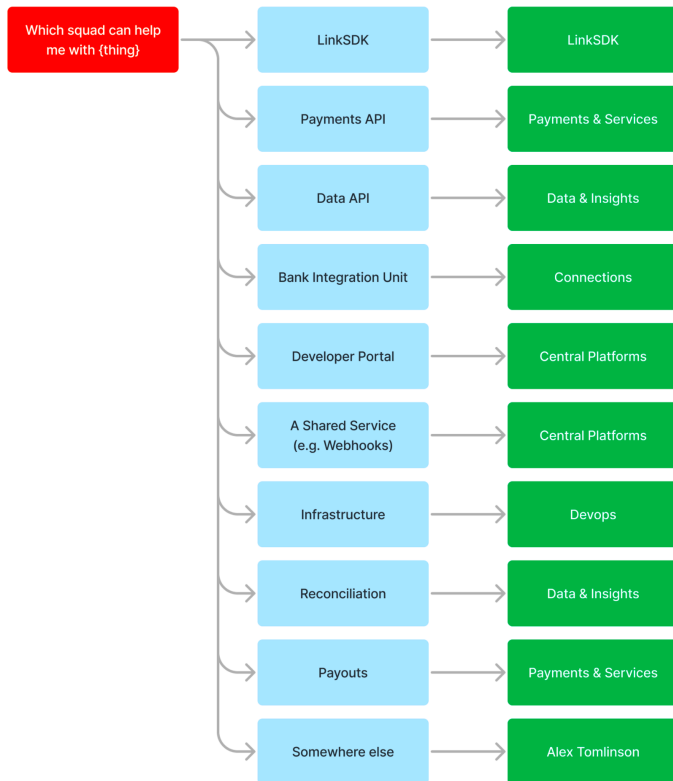
b. Segregation of Duties:

Segregation of duties (SoD) is a fundamental principle in lean management that plays a critical role in ensuring effective internal controls and reducing the risk of fraud and errors within an organization. In lean practices, SoD refers to the clear division of tasks and responsibilities among different individuals or teams to prevent any single person or department from having unchecked authority over a particular process. This separation serves as a safeguard against conflicts of interest and malicious activities, promoting transparency and accountability.

At Lean we have defined SODs which follow the Least privilege principle as per SAMA CSF requirement. The segregation of duties within the infrastructure component as shown as below.

Detailed Matrix is located here:
<https://www.notion.so/leantech/Identity-and-Access-Management-IAM-Lean-Internal-dea13b81bf8b435e993186602367aef5>

High level responsibility of SOD is as below



This matrix defines which squad has access to which application based on a defined and internally agreed RBAC model.

c. Additional Cyber security controls

At Lean Technologies, we have implemented a robust set of security controls in strict accordance with SAMA CSF requirements. These controls cover various aspects, including configuration parameters, event monitoring and retention (encompassing system access and data), data-leakage prevention (DLP), identity and access management, and remote maintenance.

Our approach to identity and access management is guided by the principle of least privilege, and we achieve this through the seamless integration of JumpCloud and Google services. These systems grant users only the access they need, promoting a secure and compliant environment.



For event monitoring and data retention, we have integrated all machines with JumpCloud Active Directory, and IT administrators maintain centralized control. This not only ensures efficient monitoring but also assists in retaining vital system access and data logs.

As a robust Data Leakage Prevention (DLP) measure, we employ the Wazuh SIEM module, which collects logs from all machines. This SIEM module diligently identifies unauthorized activities and potential malware threats within the system. To further enhance our security posture, these SIEM logs are transmitted to a centralized Security Operations Center (SOC) machine, which is outsourced to a trusted third party. This SOC team meticulously reviews the logs, promptly identifying security events and issues. In the event of any anomalies, Lean Technologies is immediately notified, enabling swift and effective responses to potential threats.

In summary, Lean Technologies has taken a comprehensive approach to security controls, encompassing identity and access management, event monitoring, data retention, and data-leakage prevention. These measures are meticulously designed to align with SAMA CSF requirements and ensure the highest level of security and compliance in our operations.

d. Backup and Recovery

Procedure

- **Regular Scheduling:** Backups must be performed on a regular schedule, with the frequency determined by the data's criticality and rate of change.
- **Data Prioritization:** Critical data, as identified in the asset classification process, must be prioritized for backup. Backup schedules and methods must reflect the importance and sensitivity of the data.
- **Automated Processes:** Where possible, backups should be automated to reduce the risk of human error and to ensure consistency and reliability.

Data Redundancy

- **Offsite Storage:** In addition to on-premises backups, copies of critical backups should be stored in a geographically separate location to protect against regional disasters.
- **Cloud Solutions:** Where appropriate, the use of cloud-based backup solutions should be explored to enhance the robustness and scalability of backup operations.

Backup Testing



- Regular Validation: Backup procedures must be regularly tested to ensure that they are functioning correctly. This includes verifying that data can be accurately restored from backup media.
- Recovery Drills: Conduct regular recovery drills to ensure that IT staff are familiar with recovery procedures and to validate the effectiveness of these procedures.

Secure Backup Storage

- Encryption: All backup data must be encrypted both in transit and at rest to protect sensitive information from unauthorized access.
- Access Control: Access to backup data should be strictly controlled and limited to authorized personnel only. Authentication mechanisms must be enforced.

Recovery Procedures

- Defined RTOs and RPOs: Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) must be defined and adhered to, based on the criticality of the systems and data.
- Documentation: Detailed recovery procedures must be documented and readily available to personnel responsible for recovery operations.
- Service Continuity: Strategies must be in place to minimize service downtime during recovery operations, including the use of redundant systems and interim solutions.

4.11 Periodic Cybersecurity Compliance Review

At Lean Technology, we regard the periodic cybersecurity compliance review as a fundamental aspect of our cybersecurity strategy. This practice exemplifies our dedication to maintaining the highest security standards, adapting to the changing threat landscape, and delivering dependable solutions to our clients.

In addition to our robust cybersecurity practices, Lean Technology Company emphasizes the importance of conducting regular cybersecurity compliance reviews. These reviews are essential to ensure that our cybersecurity measures align seamlessly with the Security Assurance and Cyber Resilience Framework (SAMA CSF), the industry-recognized standard that guides our efforts in safeguarding sensitive data and critical assets.

Key Elements of the Compliance Review:

- **Alignment with Regulatory Requirements:** We meticulously assess our cybersecurity protocols, policies, and practices to confirm alignment with the evolving regulatory landscape, with a primary focus on SAMA CSF compliance.
- **Continuous Updates:** Regular compliance reviews empower us to stay agile in adapting to emerging threats and new regulatory standards. Any necessary adjustments to our cybersecurity measures are made promptly to address identified gaps.
- **Risk Mitigation:** The compliance review process is intricately connected to our risk management strategy. By identifying vulnerabilities and enhancing our protective measures, we minimize the risk of security breaches and data exposure.
- **Stakeholder Accountability:** Clear accountability is established throughout the organization. The compliance review ensures that all team members understand their roles and responsibilities in maintaining cybersecurity standards.

4.12 Measuring and Evaluating Compliance with Infrastructure Security Controls

To ensure continuous compliance with the Infrastructure Security Standard, the organization shall implement a structured approach for periodic measurement and evaluation of security controls. Compliance monitoring shall be conducted using industry-standard frameworks, including the CIS Benchmarks, CloudGuard, and Nessus Infrastructure Vulnerability Assessments (VA).

The organization will assess compliance effectiveness by tracking the following Key Performance Indicators (KPIs) on a quarterly basis:

- Number of infrastructure vulnerabilities identified and remediated through Infra VA scanning.
- Percentage of publicly exposed systems that are configured to use the latest TLS versions (1.2 or 1.3).
- Number of high/critical CIS Benchmark violations across infrastructure components.
- Number of security violations identified on privileged user accounts.
- Number of security vulnerabilities identified through internal security testing.

Additionally, bi-weekly compliance monitoring shall include checks on the following:

- SSL certificate expiration dates, ensuring timely renewal to prevent service disruptions and security risks.



- Shared hosting environments, to identify misconfigurations, security risks, and unauthorized access issues.
- Open ports and associated vulnerabilities, to detect and mitigate potential attack vectors.
- Lean IP reputation, ensuring that organization-assigned IP addresses are not blacklisted or associated with malicious activities.
- New Lean domains and subdomains that have become public, using an external attack surface management tool to identify and assess potential risks.

Security teams must review and address findings from these assessments promptly, ensuring that remediation actions align with organizational risk tolerance and compliance requirements.

4.13 Data Protection and Classification Compliance

All data assets within the organization shall be protected in accordance with their classification as per the Lean Data Classification Policy. Security and access controls must be proportionate to the sensitivity level of the data, ensuring that:

- Classified data is handled, stored, and transmitted in alignment with predefined security measures and regulatory requirements.
- Access to classified data is restricted based on the principle of least privilege (PoLP) and subject to strong authentication and access controls.
- Data encryption is enforced for storage and transmission, using cryptographic standards compliant with industry best practices.
- Data Loss Prevention (DLP) tools are deployed to monitor, detect, and prevent unauthorized data transfers, ensuring that sensitive information is not inadvertently or maliciously leaked outside the organization.
- Data retention and disposal policies are adhered to, ensuring that classified data is securely retained and destroyed based on business and regulatory requirements.
- Security monitoring and auditing mechanisms are in place to detect and respond to unauthorized access, misuse, or data breaches.

All employees and third parties handling classified data must comply with these requirements, ensuring the protection of organizational information assets against unauthorized access, loss, or compromise.

5. Roles and Responsibilities

Governance, Legal, Risk and Compliance Committee (GLRCC)

Key responsibilities of the GLRCC are the following:

- To approve this Standard on at least an annual basis.

Head of information Security

Key responsibilities of the Head of Information Security are the following:

- To monitor the compliance with the principles of this Standard and report any deviations or breaches of the Standard.
- To work closely with the IT and Engineering departments in implementing this Standard.
- To measure and periodically evaluate the effectiveness of the existing security controls.

Information Technology/Engineering

Key responsibilities of IT/Engineering departments are the following:

- To implement all the required security configurations defined in this Standard.

Internal Audit

Key responsibilities of Internal Audit are the following:

- To examine and evaluate the adequacy and effectiveness of Lean's policies, procedures and standards.
- To share the audit findings with the Head of Information Security to act on the observations and rectify any deviations or non-compliances.
- To conduct a follow up review and share any findings not resolved with GLRCC.



6. Procedures

N/A

7. Review and Updates

Lean's Infrastructure Security Standard is required to be updated annually and/or when significant changes that affect Lean's needs and operations have occurred (including after a major security incident).

The Head of Information Security is the owner of this Standard, responsible for ensuring that it is maintained up to date and committed to ensuring that this Standard is an accurate reflection of the applicable laws and regulations.

The Standard should be approved by the GLRCC. Any revision to this Standard shall specify the superseded version which shall be retained for future reference.

Appendix A: References

- <https://www.sama.gov.sa/en-US/RulesInstructions/CyberSecurity/Cyber%20Security%20Framework.pdf>
- <https://docs.oracle.com/en-us/iaas/Content/General/Concepts/regions.htm>

Appendix B: Covered assets

Operating Systems

Objective: Ensure all operating systems are secured against unauthorized access and vulnerabilities.

- Security Controls:
 - Regular patch management and updates.
 - Configuration and hardening guidelines.
 - Use of security baselines and benchmarks (e.g., CIS Benchmarks).
 - User account management and privilege restriction.

Servers

Objective: Secure physical and virtual servers to protect critical data and services.

- Security Controls:
 - Physical security measures for server rooms.
 - Virtualization security practices.
 - Server hardening procedures.
 - Monitoring and logging of server activities.

Virtual Machines

Objective: Implement security measures specific to virtual environments.

- Security Controls:
 - Segregation and isolation of virtual machines.
 - Management of hypervisor security.



- Implementation of virtual network security controls.
- Backup and recovery processes for virtual machines.

Firewalls

Objective: Utilize firewalls to control traffic and prevent unauthorized network access.

- Security Controls:
 - Proper firewall configuration and management.
 - Rule base management and review.
 - Integration with intrusion detection and prevention systems.
 - Regular audits and logs review.

Network Devices

Objective: Secure all network devices to prevent unauthorized data access and ensure data integrity.

- Security Controls:
 - Device hardening and reduction of attack surface.
 - Use of secure protocols for management (e.g., SSH, SNMPv3).
 - Regular updates and patch management.
 - Network segmentation and access control lists.

Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS)

Objective: Deploy IDS and IPS to monitor and protect against malicious activities and attacks.

- Security Controls:
 - Proper placement and tuning of IDS/IPS.
 - Regular updates to signature databases.
 - Integration with other security systems for coordinated response.
 - Continuous monitoring and alert management.

Wireless Networks

Objective: Ensure the security and integrity of wireless communications.



- Security Controls:
 - Use of strong encryption standards (e.g., WPA3).
 - Secure wireless access authentication methods.
 - Regular testing and security assessments.
 - Guest network isolation and management.

Gateway Servers

Objective: Secure gateway servers to control data flow and prevent threats from entering the network.

- Security Controls:
 - Hardening of gateway systems.
 - Monitoring and controlling ingress and egress traffic.
 - Implementation of antimalware and antispam solutions.
 - Use of VPNs for secure remote access.

Proxy Servers

Objective: Utilize proxy servers to filter web traffic and enforce internet usage policies.

- Security Controls:
 - Configuration of secure proxy settings.
 - Blocking access to malicious websites.
 - Integration with threat intelligence for real-time protection.
 - User authentication and access controls.

Email Gateways

Objective: Secure email communications and prevent phishing, spam, and malware distribution.

- Security Controls:
 - Implementation of email filtering solutions.
 - Use of SPF, DKIM, and DMARC to combat email spoofing.
 - Encryption of email transmissions.
 - Regular user training on email security awareness.

Databases

Objective: Protect databases from unauthorized access and ensure data confidentiality and integrity.

- Security Controls:
 - Database encryption, both at rest and in transit.
 - Implementation of access controls and auditing.
 - Regular database backups and replication.
 - Application of security patches and vulnerability management.

MacOS Laptops

Objective: Secure MacOS laptops against theft, loss, and cyber-attacks.

- Security Controls:
 - Full disk encryption (e.g., FileVault).
 - Configuration and security setting management via MDM.
 - Application whitelisting and malware protection.
 - Secure VPN connections for remote access.